

Clase 277 — Gestión de riesgos: cuantitativa y cualitativa

Parte: **14 — GRC, riesgo y cumplimiento** · Fuente: *How to Measure Anything in Cybersecurity Risk (Hubbard & Seiersen)* 🕒 Duración estimada: **120 min** · Nivel: **Intermedio**

Objetivo

Aprender a evaluar el riesgo de seguridad de forma rigurosa, tanto con métodos cualitativos (matrices de probabilidad × impacto) como cuantitativos (SLE, ARO, ALE y modelos probabilísticos). Al terminar sabrás calcular la pérdida anual esperada de un escenario, decidir si un control se justifica económicamente y comunicar riesgo en términos que la dirección entiende: dinero y probabilidad, no colores.

Resultados de aprendizaje

Al finalizar, el alumno podrá:

- 1. **Calcular** SLE, ARO y ALE de un escenario de riesgo concreto.
- 2. **Construir** una matriz de riesgo cualitativa 5×5 y ubicar riesgos en ella.
- 3. **Comparar** el ALE antes y después de un control para justificar la inversión (ROSI).
- 4. **Aplicar** una estimación probabilística por rangos con intervalos de confianza del 90%.
- 5. **Elegir** el tratamiento adecuado: mitigar, transferir, evitar o aceptar.

Temas

#	Tema	Por qué importa
1	Vocabulario: amenaza, vulnerabilidad, riesgo	Base común para razonar
2	Análisis cualitativo (matriz P×I)	Rápido para priorizar, útil como triaje
3	Análisis cuantitativo (SLE/ARO/ALE)	Traduce riesgo a euros
4	ROSI (retorno de la inversión en seguridad)	Justifica presupuesto
5	Estimación calibrada y rangos	Supera la falacia de la "medición imposible"
6	Simulación de Montecarlo	Modela incertidumbre realista
7	Tratamiento del riesgo	Del análisis a la decisión

Definiciones y características

- **Riesgo:** probabilidad de que una amenaza explote una vulnerabilidad causando un impacto. *Clave:* riesgo = f(probabilidad, impacto).
- **SLE (Single Loss Expectancy):** pérdida esperada de un único incidente. *Clave:* SLE = Valor del activo (AV) × Factor de exposición (EF).

- **ARO (Annualized Rate of Occurrence)**: número esperado de ocurrencias al año. *Clave*: 0,1 significa "una vez cada 10 años".
- **ALE (Annualized Loss Expectancy)**: pérdida anual esperada. *Clave*: $ALE = SLE \times ARO$.
- **ROSI**: retorno de inversión en seguridad. *Clave*: $ROSI = (ALE_{antes} - ALE_{después} - coste_control) / coste_control$.
- **Riesgo residual**: el que queda tras aplicar controles. *Clave*: nunca es cero; se acepta formalmente.
- **Estimación calibrada**: dar rangos con un intervalo de confianza (p. ej. 90%) en lugar de un punto. *Clave*: reduce el exceso de confianza del experto.

Herramientas y preparación

- Hoja de cálculo (LibreOffice Calc / Excel / Google Sheets) para las fórmulas SLE/ARO/ALE.
- Opcional: Python con `numpy` para una simulación de Montecarlo (`pip install numpy`).
- Referencia metodológica: *FAIR* (Factor Analysis of Information Risk) de The Open Group, y *NIST SP 800-30* (Guide for Conducting Risk Assessments).
- Una plantilla de matriz de riesgo 5x5 (la crearás tú en el laboratorio).

Laboratorio guiado (ejercicio aplicado)

Escenario: ransomware contra la plataforma de e-commerce de "Ferretería del Sur S.A.".

1. **Valora el activo (AV)**: estima el valor de la plataforma en 500.000 €.
2. **Factor de exposición (EF)**: un cifrado por ransomware deja el sistema inoperante; estima EF = 0,6 (pérdida del 60%).
3. **SLE**: calcula $SLE = 500.000 \times 0,6 = 300.000 \text{ €}$.
4. **ARO**: según incidentes del sector estimas 0,2 (uno cada 5 años). Calcula $ALE = 300.000 \times 0,2 = 60.000 \text{ €/año}$.
5. **Control propuesto**: backups inmutables + EDR por 25.000 €/año, que reducen el ARO a 0,05. Nuevo $ALE_{después} = 300.000 \times 0,05 = 15.000 \text{ €}$.
6. **ROSI**: $(60.000 - 15.000 - 25.000) / 25.000 = 0,8 \rightarrow 80\%$ de retorno. El control se justifica.
7. **Matriz cualitativa**: dibuja una tabla 5x5 (probabilidad x impacto), ubica el riesgo antes (alto-alto) y después del control (bajo-alto) y colorea.
8. **Estimación calibrada**: en lugar de fijar ARO=0,2, exprésalo como rango 90%: "entre 0,1 y 0,4". Anota cómo cambia el ALE en los extremos (30.000–120.000 €).
9. **(Opcional) Montecarlo**: en Python, muestrea EF y ARO de distribuciones y calcula la distribución del ALE:

```
import numpy as np
n = 100000
av = 500000
ef = np.random.triangular(0.4, 0.6, 0.8, n)
aro = np.random.triangular(0.1, 0.2, 0.4, n)
ale = av * ef * aro
print(f"ALE medio: {ale.mean():.0f} € P90: {np.percentile(ale, 90):.0f} €")
```

Ejercicios

1. Calcula el ALE de un robo de portátil: AV=1.500 €, EF=1, ARO=3.

2. Un control cuesta 10.000 € y baja el ALE de 40.000 a 12.000 €. ¿Cuál es el ROSI?
3. Convierte esta matriz cualitativa a decisión: probabilidad media, impacto catastrófico. ¿Aceptas o mitigas?
4. Da un intervalo de confianza del 90% para "cuántos empleados hará clic en un phishing de 100 enviados". Justifica.
5. Explica por qué el ALE puede engañar cuando el impacto es raro pero catastrófico (cola larga).
6. Diseña un Montecarlo para una brecha de datos con multa GDPR variable.

Reto verificable

Entrega una **hoja de cálculo de análisis de riesgo cuantitativo** para tres escenarios (ransomware, brecha de datos, caída de disponibilidad) con SLE, ARO, ALE, control propuesto, ALE residual y ROSI de cada uno, más una matriz cualitativa 5×5 que los ubique.

Criterio de aceptación: las fórmulas están enlazadas (no números pegados), cada control muestra un ROSI calculado, y la recomendación de tratamiento (mitigar/transferir/aceptar) es coherente con el ROSI y la posición en la matriz.

Errores comunes

Síntoma / mensaje	Causa y cómo arreglar
ALE ridículamente preciso (60.000,00 €)	Falsa precisión; usa rangos con intervalos de confianza
Matriz de colores sin acción	La matriz es triaje, no decisión final; complementa con cuantitativo
ROSI negativo pero se compra el control	Decisión emocional; revisa si hay factor regulatorio o reputacional no modelado
"El riesgo no se puede medir"	Falacia; toda reducción de incertidumbre es medición (Hubbard)
Ignorar el riesgo residual	Documenta y acepta formalmente lo que queda

Preguntas frecuentes

? ¿Cuantitativo o cualitativo? Ambos. El cualitativo prioriza rápido; el cuantitativo justifica inversiones y se comunica con la dirección. Empieza cualitativo, profundiza cuantitativo en los riesgos top.

? ¿De dónde saco el ARO si no tengo datos? De informes del sector (Verizon DBIR), datos históricos internos y estimación calibrada por expertos. La incertidumbre se modela, no se elimina.

? ¿Qué es FAIR? Un marco cuantitativo estándar que descompone el riesgo en frecuencia y magnitud de pérdida. Complementa muy bien SLE/ARO/ALE.

? ¿La matriz 5×5 tiene problemas? Sí: distorsiona por rangos arbitrarios y "colores". Úsala como triaje, no como única base de decisión (crítica de Hubbard).

Referencias

- Hubbard & Seiersen — How to Measure Anything in Cybersecurity Risk.
<https://www.howtomeasureanything.com/cybersecurity/>
- NIST SP 800-30 Rev.1 — Guide for Conducting Risk Assessments.
<https://csrc.nist.gov/pubs/sp/800/30/r1/final>
- The Open Group — FAIR Risk Analysis Standard. <https://www.opengroup.org/forum/security/fair>
- Verizon Data Breach Investigations Report (DBIR).
<https://www.verizon.com/business/resources/reports/dbir/>
- (ISC)² CISSP Official Study Guide, dominio 1.

Siguiente clase

Clase 278 - ISO/IEC 27001 e implantacion de un SGSI